

Politique de gestion des tiers et sous-traitants

1. Objectif

Définir les règles de sélection, d'évaluation, de contractualisation et de supervision des tiers et sous-traitants afin de garantir que tout partenaire respecte les exigences de sécurité, de confidentialité et de conformité réglementaire de la plateforme.

2. Périmètre

S'applique à tous les tiers : - Hébergeurs cloud - Fournisseurs SMS / email - Prestataires de paiement - Intégrateurs techniques - Sous-traitants IT - Consultants - Fournisseurs de services IA

3. Typologie des tiers

- Tiers critiques (accès aux données sensibles)
- Tiers importants (services essentiels sans accès direct aux données)
- Tiers non critiques

4. Processus de sélection

- Évaluation sécurité préalable
- Vérification conformité réglementaire
- Analyse de risques
- Validation par la direction

5. Exigences contractuelles

- Clauses de confidentialité
- Clauses de protection des données
- Clauses de notification d'incident
- Droits d'audit
- Obligations de continuité d'activité

6. Évaluation et due diligence

- Questionnaire sécurité
- Certifications (ISO 27001, équivalent)
- Historique d'incidents
- Capacité de résilience

7. Supervision continue

- Revue annuelle des tiers critiques
- Indicateurs de performance et sécurité
- Rapports périodiques

8. Gestion des accès tiers

- Accès limités
- Comptes dédiés
- Journalisation
- Révocation immédiate en fin de contrat

9. Sous-traitance en cascade

- Autorisation préalable obligatoire
- Transparence sur les sous-traitants secondaires

10. Gestion des incidents impliquant des tiers

- Notification immédiate
- Coordination avec le plan de gestion des incidents

11. Conformité et références

- ISO/IEC 27001 (A.15 – Supplier Relationships)
- NIST SP 800-161 (Supply Chain Risk Management)
- Bonnes pratiques de gestion des fournisseurs IT

12. Responsabilités

- Direction
- RSSI
- Achats
- Juridique
- Responsables métiers

13. Mise à jour

- Revue annuelle
- Mise à jour après changement majeur de fournisseur

Document de référence interne – Gestion des tiers et sous-traitants pour la plateforme de gestion numérique des auto-écoles et examens.